UNITÉ D'ÉTUDE CINQ CONTRÔLES : TYPES ET CADRES

Cette unité d'étude est la troisième d'une série de quatre portant sur le **domaine V : Gouvernance, gestion des risques et contrôle** du programme d'examens CIA de l'IIA. Ce domaine représente 35 % de la partie 1 de l'examen CIA et est évalué au niveau cognitif de **base** et de **compétence.** La partie pertinente du syllabus est mise en évidence ci-dessous. (L'abus complet de la syllabe se trouve à l'annexe B.)

	Gouvernance, gestion des risques et contrôle (35 %)		
	A	Décrire le concept de gouvernance organisationnelle	De base
	B	Reconnaître l'impact de la culture organisationnelle sur l'environnement de contrôle global et sur les risques et les contrôles de l'engagement individuel.	De base
	C	Reconnaître et interpréter les questions liées à l'éthique et à la conformité de l'organisation, les violations présumées et les dispositions.	De base
	D	Décrire la responsabilité sociale de l'entreprise	De base
	E	Interpréter les concepts fondamentaux du risque et le processus de gestion du risque	Compétent
V	F	Décrire les cadres de gestion des risques acceptés à l'échelle mondiale qui conviennent à l'organisation (COSO - ERM, ISO 31000, etc.).	De base
	G	Examiner l'efficacité de la gestion des risques au sein des processus et des fonctions	Compétent
	H	Reconnaître la pertinence du rôle de l'activité d'audit interne dans le processus de gestion des risques de l'organisation.	De base
	I	**Interpréter les concepts de contrôle interne et les types de contrôles**	**Compétent**
	J	**Appliquer des cadres de contrôle interne globalement acceptés et adaptés à l'organisation (COSO, etc.)**	**Compétent**
	K	**Examiner l'efficacité et l'efficience des contrôles internes**	**Compétent**

De nombreuses questions sur l'examen CIA portent sur les contrôles. Peu de questions de ce genre peuvent être répondues en se basant sur la mémorisation des listes. En outre, aucun texte ne peut présenter des listes complètes de procédures. Ainsi, les candidats doivent être capables d'appliquer les processus de raisonnement et la connaissance des concepts d'audit à des situations peu familières impliquant des contrôles. En répondant à nos questions, vous serez en mesure de synthétiser, comprendre et appliquer la théorie du contrôle interne. L'analyse permet de comprendre une situation, un ensemble de circonstances ou un processus. La synthèse consiste à élaborer des normes et des généralisations pour une situation, un ensemble de circonstances ou un processus. C'est un moyen de combiner des composants individuels ou des pièces pour produire un tout. La synthèse exige un raisonnement inductif, qui consiste à tirer une conclusion généralisée à partir de cas particuliers. L'évaluation consiste à relier une situation, un ensemble de circonstances ou un processus à des normes prédéterminées ou synthétisées. L'évaluation comprend habituellement à la fois l'analyse et la synthèse. Cet ensemble de compétences vous permettra de répondre avec confiance à toute question sur l'examen CIA.

I. VUE D'ENSEMBLE DU CONTROLE

1. **Définitions tirées du glossaire de l'IIA** (l'annexe A contient le glossaire complet de l'IIA).

Le contrôle est " toute mesure prise par la direction, le conseil et les autres parties pour gérer les risques et accroître la probabilité que les objectifs et les buts établis soient atteints ". La direction planifie, organise et dirige l'exécution de mesures suffisantes pour fournir une assurance raisonnable que les objectifs et les buts seront atteints."

Les processus de contrôle sont " les politiques, les procédures (manuelles et automatisées) et les activités qui font partie d'un cadre de contrôle conçu et mis en œuvre pour s'assurer que les risques sont contenus dans le niveau qu'une organisation est disposée à accepter ".

L'environnement de contrôle est " l'attitude et les actions du conseil et de la direction concernant l'importance du contrôle au sein de l'organisation. L'environnement de contrôle fournit la discipline et la structure nécessaires à la réalisation des principaux objectifs du système de contrôle interne. L'environnement de contrôle comprend les éléments suivants :

- Intégrité et valeurs éthiques
- Philosophie et mode de fonctionnement de la direction
- Structure organisationnelle
- Attribution de l'autorité et de la responsabilité
- Politiques et pratiques en matière de ressources humaines
- Compétence du personnel"

2. **Le processus de contrôle**

Le contrôle exige une rétroaction sur les résultats des activités organisationnelles aux fins de mesure et de correction.

Le processus de contrôle comprend :

- Établir des normes pour l'opération à contrôler,
- Mesurer le rendement par rapport aux normes,
- Examiner et analyser les écarts,
- Prendre des mesures correctives, et
- Réévaluer les normes sur la base de l'expérience.

Un système d'évaluation-récompense devrait être mis en œuvre pour encourager le respect du système de contrôle.

Le contrôle interne ne fournit qu'une assurance raisonnable quant à l'atteinte des objectifs. Il ne peut fournir une assurance absolue, car tout système de contrôle interne comporte les limites inhérentes suivantes :

- **Le jugement humain** est erroné et les contrôles peuvent échouer à cause de simples erreurs ou d'erreurs.
- **La direction** peut outrepasser de façon inappropriée les contrôles internes, p. ex. pour réaliser frauduleusement des projections de revenus ou cacher des passifs.
- Les contrôles manuels ou automatisés peuvent être contournés par **collusion**.
- Le **coût** du contrôle interne ne doit pas être supérieur à ses **avantages**.

3. Caractéristiques du traitement automatisé

L'utilisation d'ordinateurs dans les systèmes d'information de l'entreprise a des effets fondamentaux sur la nature des transactions commerciales, les procédures suivies, les risques encourus et les méthodes d'atténuation de ces risques. Ces effets découlent des caractéristiques qui distinguent le traitement informatisé du traitement manuel.

a. Piste des transactions

Une piste complète utile à l'audit et à d'autres fins pourrait n'exister que pour une courte période ou seulement sous une forme lisible par ordinateur. La nature de la piste dépend souvent du mode de traitement des transactions, par exemple, si les transactions sont mises en lots avant le traitement ou si elles sont traitées immédiatement lorsqu'elles surviennent.

b. Traitement uniforme des transactions

Le traitement informatique soumet uniformément des opérations semblables aux mêmes instructions de traitement et élimine ainsi pratiquement toute erreur d'écriture, mais les erreurs de programmation (ou d'autres erreurs systématiques semblables dans le matériel ou le logiciel) entraîneront le traitement incorrect de toutes les opérations semblables lorsqu'elles sont traitées dans les mêmes conditions.

c. Séparation des fonctions

De nombreux contrôles autrefois effectués par des personnes distinctes peuvent être concentrés dans des systèmes informatiques. Par conséquent, une personne qui a accès à l'ordinateur peut exécuter des fonctions incompatibles. En conséquence, d'autres contrôles peuvent être nécessaires pour atteindre les objectifs de contrôle habituellement atteints par la séparation des fonctions.

d. Possibilité d'erreurs et de fraude

Le risque que des personnes, y compris celles qui effectuent des procédures de contrôle, aient un accès non autorisé aux données, modifient des données sans preuve visible ou aient accès (directement ou indirectement) à des biens peut être plus grand dans les systèmes informatiques. Une diminution de la participation humaine dans le traitement des transactions peut réduire le risque d'erreurs et de fraudes. Les erreurs ou les fraudes dans la conception ou le changement des programmes d'application peuvent rester longtemps inaperçues.

e. Possibilité d'une supervision accrue de la gestion

Les systèmes informatiques offrent à la direction de nombreux outils d'analyse pour l'examen et la supervision des opérations. Ces contrôles supplémentaires peuvent améliorer le contrôle interne. Par exemple, les comparaisons traditionnelles des ratios d'exploitation réels et budgétés et les rapprochements de comptes sont souvent disponibles pour examen plus rapidement. De plus, certaines applications programmées fournissent des statistiques sur les opérations informatiques qui peuvent être utilisées pour surveiller le traitement réel.

f. **Initiation ou exécution ultérieure de transactions par ordinateur**

Certaines opérations peuvent être initiées automatiquement ou certaines procédures nécessaires à l'exécution d'une opération peuvent être exécutées automatiquement par un système informatique. L'autorisation de ces transactions ou procédures peut ne pas être documentée de la même manière que dans un système manuel, et l'autorisation de la direction peut être implicite dans son acceptation de la conception du système.

g. **Dépendance des contrôles dans d'autres domaines à l'égard des contrôles sur le traitement informatique**

Le traitement informatique peut produire des rapports et d'autres résultats qui sont utilisés dans l'exécution des procédures de contrôle manuel. L'efficacité de ces contrôles peut dépendre de l'efficacité des contrôles sur l'intégralité et l'exactitude du traitement informatique. Par exemple, l'efficacité d'un examen manuel d'une liste d'exceptions produite par ordinateur dépend des contrôles sur la production de la liste.

h. **Contrôles manuelles par rapport aux contrôles automatisées**

Les contrôles manuels peuvent être plus appropriés lorsqu'il faut faire preuve de jugement et de discrétion, comme dans les cas suivants

- Pour les transactions importantes, inhabituelles ou non récurrentes ;
- Pour les circonstances où les inexactitudes sont difficiles à définir, à prévoir ou à prédire ;
- Dans des circonstances changeantes qui exigent une réponse de contrôle hors de la portée d'un contrôle automatisé existant ; et
- En surveillant l'efficacité des contrôles automatisés.

Les contrôles automatisés conviennent pour

- Transactions à volume élevé qui nécessitent des calculs supplémentaires.
- Des erreurs de routine qui peuvent être prédites et corrigées.
- Circonstances qui exigent un degré élevé d'exactitude.

4. **Rôles des auditeurs internes dans le contrôle**

Norme de fonctionnement 2130 – Contrôle. L'audit interne doit aider l'organisation à maintenir un dispositif de contrôle approprié en évaluant son efficacité ainsi que son efficience et en encourageant son

amélioration continue.

Norme de mise en œuvre 2130.A1 – L'audit interne doit évaluer la pertinence et l'efficacité du dispositif de contrôle choisi pour faire face aux risques relatifs à la gouvernance, aux opérations et systèmes d'information de l'organisation. Cette évaluation doit porter sur les aspects suivants :

- l'atteinte des objectifs stratégiques de l'organisation ;
- la fiabilité et l'intégrité des informations financières et opérationnelles ;
- l'efficacité et l'efficience des opérations et des programmes ;
- la protection des actifs ;
- le respect des lois, règlements, règles, procédures et contrats.

Norme de mise en œuvre 2130.C1 – Les auditeurs internes doivent utiliser leurs connaissances des dispositifs de contrôle acquises lors de missions de conseil lorsqu'ils évaluent les processus de contrôle de l'organisation.

Norme de mise en œuvre 2210.A3 – Des critères adéquats sont nécessaires pour évaluer la gouvernance, le management des risques et le dispositif de contrôle. Les auditeurs internes doivent déterminer dans quelle mesure le management et/ou le Conseil a défini des critères adéquats pour apprécier si les objectifs et les buts ont été atteints. Si ces critères sont adéquats, les auditeurs internes doivent les utiliser dans leur évaluation. S'ils sont inadéquats, les auditeurs internes doivent identifier, à travers une discussion avec le management et le Conseil, les critères d'évaluation appropriés.

Le **guide de mise en œuvre 2130, *Contrôle***, fournit d'autres directives sur les responsabilités de l'audit interne en matière de contrôles :

1) Les contrôles **atténuent les risques** au niveau de l'entité, de l'activité et des transactions.
2) Les rôles et responsabilités sont les suivants :
   - ✓ **La direction générale** supervise l'établissement, l'administration et l'évaluation du système de contrôles.
   - ✓ **Les gestionnaires** évaluent les contrôles dans le cadre de leurs responsabilités.
   - ✓ Les **auditeurs internes** fournissent l'assurance de l'efficacité des contrôles existants.
3) Dans l'exercice de leurs responsabilités, les auditeurs internes devraient :
   - ✓ Comprendre clairement le contrôle et les processus de contrôle typiques
   - ✓ Tenir compte de l'appétit pour le risque, de la tolérance au risque et de la culture du risque.
   - ✓ Comprendre (1) les risques critiques qui pourraient empêcher d'atteindre les objectifs et (2) les contrôles qui atténuent les risques
   - ✓ Comprendre le(s) cadre(s) de contrôle utilisé(s)

- ✓ Disposer d'un processus de planification, de vérification et d'établissement de rapports sur les problèmes de contrôle.

4) Évaluation de l'**efficacité des** contrôles

Les contrôles devraient être évalués en fonction des risques à chaque niveau. Une **matrice des risques et des contrôles** peut être utile pour :

- ✓ Déterminer les objectifs et les risques connexes.
- ✓ Déterminer l'importance des risques (impact et probabilité).
- ✓ Déterminer les réponses aux risques importants (par exemple, accepter, poursuivre, transférer, atténuer ou éviter).
- ✓ Déterminer les contrôles de gestion clés.
- ✓ Évaluer la pertinence de la conception des contrôles.
- ✓ Mettre à l'essai des contrôles bien conçus pour vérifier s'ils ont été mis en œuvre et s'ils fonctionnent efficacement.

5) Évaluation de l'**efficience des** contrôles

Les auditeurs internes examinent si la direction surveille les **coûts et les avantages** du contrôle. La question est de savoir si (1) les ressources utilisées dépassent les avantages et (2) les contrôles créent des problèmes importants (par exemple, erreur, retard ou double emploi).

Le niveau d'un contrôle doit être adapté au risque concerné.

6) Promouvoir l'**amélioration continue**

Le RAI peut recommander un **cadre de contrôle** s'il n'en existe pas. L'activité d'audit interne peut également recommander des améliorations de l'**environnement de contrôle** (par exemple, le ton au sommet devrait promouvoir une culture éthique et ne pas tolérer la non-conformité).

L'amélioration continue des contrôles implique

- ✓ Formation et auto-surveillance continue
- ✓ Réunions d'évaluation du contrôle (ou du risque et du contrôle) avec les gestionnaires
- ✓ Une structure logique pour la documentation, l'analyse et l'évaluation de la conception et de l'exploitation
- ✓ Identification, évaluation et correction des faiblesses de contrôle
- ✓ Information des gestionnaires sur les nouvelles questions, lois et règlements
- ✓ Suivi des développements techniques pertinents

II. TYPES DE CONTRÔLES

1. Contrôles primaires ou principaux

Des contrôles préventifs découragent la survenue d'événements indésirables. L'entreposage de la petite caisse dans un coffre-fort verrouillé et la séparation des tâches, p. ex. l'utilisation d'un

système de casiers, en sont des exemples. Les exemples de TI comprennent (a) la conception d'une base de données de sorte que les utilisateurs ne puissent pas entrer une lettre dans le champ qui stocke un numéro de sécurité sociale et (b) l'exigence que le nombre de factures d'un lot soit entré avant le début du traitement.

Les contrôles de détectifs alertent les bonnes personnes après un événement indésirable. Ils sont efficaces lorsqu'ils sont détectés avant que des dommages matériels ne se produisent. Par exemple, un lot de factures soumises pour traitement peut être rejeté par le système informatique s'il comprend des paiements identiques à un seul fournisseur. Un contrôle de détection permet de signaler automatiquement au service des comptes fournisseurs tous les lots rejetés. L'alarme antivol en est un autre exemple.

Des contrôles correctifs corrigent les effets négatifs des événements indésirables. Un exemple est l'exigence selon laquelle tous les écarts de coûts au-delà d'un certain montant doivent être justifiés.

Les contrôles directifs provoquent ou encouragent la survenance d'un événement souhaitable. Il s'agit notamment de ce qui suit :

- Manuels de politiques et de procédures
- Formation des employés
- Descriptions d'emploi

2. Contrôles secondaires

Les contrôles compensatoires (d'atténuation) peuvent réduire les risques lorsque les contrôles primaires sont inefficaces. Toutefois, elles ne permettent pas, à elles seules, de ramener le risque à un niveau acceptable. Un exemple est l'absence de séparation des tâches lorsqu'un commis de magasin est le seul employé présent à la fermeture. Par conséquent, le commis compte l'argent comptant à la fin de la journée sans supervision. Le contrôle de compensation effectué le lendemain matin consiste pour un superviseur à rapprocher le comptage avec les données de la caisse enregistreuse.

Les contrôles complémentaires s'ajoutent à d'autres contrôles pour réduire les risques à un niveau acceptable. En d'autres termes, leur synergie est plus efficace que l'un ou l'autre contrôle par lui-même. Par exemple, la séparation des fonctions de comptabilité et de conservation des encaissements est complétée par l'obtention de bordereaux de dépôt validés par la banque.

3. Deux modes de traitement de base

a. Traitement par lots

Dans ce mode, les transactions sont accumulées et soumises à l'ordinateur en un seul lot. Dans les premiers temps de l'informatique, c'était la seule façon de traiter un travail.

Dans le traitement par lots, l'utilisateur ne peut pas influencer le processus une fois le travail commencé (sauf pour demander qu'il soit interrompu complètement). Il doit attendre jusqu'à ce que le travail soit terminé pour voir si des transactions dans le lot ont été rejetées et n'ont pas été

affichées. Malgré les énormes progrès de la technologie informatique, cette accumulation de transactions à traiter en différé est encore largement utilisée. Il est très efficace pour des applications telles que la paie, car un grand nombre d'opérations de routine doivent être traitées selon un calendrier régulier.

La **comptabilisation de notes** est utilisée par les banques pour des transactions financières et autres pour créer des entrées en temps réel qui sont envoyées vers un fichier mémo temporaire. Le fichier mémo permet la consultation des informations mises à jour. À une heure prévue, le fichier mémo est traité par lots afin de mettre à jour le fichier maître. De cette manière, les données sont disponibles immédiatement à des fins de consultation, mais les contrôles de traitement par lots sont appliqués avant que les changements ne deviennent permanents. La **comptabilisation de notes** est une étape intermédiaire entre le traitement par lots et le traitement en temps réel.

b. **Traitement en ligne, en temps réel**

Dans certains systèmes, il est essentiel de disposer à tout moment des informations les plus récentes pour assurer le bon fonctionnement du système. Un système de réservation de billets d'avion en est un exemple courant.

Dans un système en ligne et en temps réel, la base de données est mise à jour dès la saisie de la transaction par l'opérateur. Ces systèmes sont appelés systèmes de **traitement transactionnel en ligne (OLTP).**

4. Contrôles généraux Informatique

Les contrôles sur les technologies de l'information et les technologies connexes peuvent être classés en deux grandes catégories : (1) Contrôles généraux informatiques et (2) contrôles d'application.

Selon les GTAGs de l'IIA, les contrôles généraux informatique sont ceux qui se rapportent à tous les composants, processus et données des systèmes présents dans l'environnement TI d'une organisation. Les objectifs des contrôles généraux de la TI sont d'assurer le développement et la mise en œuvre appropriés des applications, ainsi que l'intégrité des fichiers de programmes et de données et des opérations informatiques.

Les contrôles généraux informatiques les plus courants sont les suivants :

- Contrôles d'accès logiques (p. ex., mots de passe) sur l'infrastructure, les applications et les données
- Contrôles du cycle de vie du développement des systèmes
- Contrôles de gestion des changements de programme
- Contrôles de sécurité physique sur le centre de données
- Contrôles de sauvegarde et de récupération des systèmes et des données

5. Contrôles d'application

Selon les GTAGs de l'IIA, les contrôles d'application sont ceux qui ont trait à la portée des processus opérationnels ou des systèmes d'application individuels. L'objectif des contrôles de l'application est de s'assurer que

- Les données d'entrée sont exactes, complètes, autorisées et correctes.
- Les données sont traitées comme prévu dans un délai acceptable.
- Les données stockées sont exactes et complètes.
- Les extrants sont précis et complets.
- Un registre est tenu à jour pour suivre le processus de traitement des données, de l'entrée au stockage et à la sortie finale.

Lors de la conception des contrôles d'entrée des données, il faut accorder la priorité à l'autorisation, à la validation et à la notification des erreurs.

Le point le plus économique pour corriger les erreurs de saisie dans une application est le moment où les données sont saisies dans le système. Pour cette raison, les contrôles d'entrée sont au cœur de l'évaluation des contrôles d'application par un auditeur interne. Chacun des deux principaux types de modes de traitement a ses propres commandes.

a. Contrôles sur les entrées

Les contrôles sur les entrées sont destinés à empêcher les erreurs informatiques en contrôlant les données lors de leur saisie manuelle ou électronique dans le système. Les erreurs de saisie sont les sources les plus fréquentes d'erreur et les auditeurs internes doivent mettre l'accent sur les tests de ces contrôles. Les faux en entrée/faux en sortie (GIGO, « garbage-in, garbage-out ») désignent le fait que quelle que soit la qualité de traitement et de sortie, si les entrées sont erronées, les sorties le seront également. Les contrôles sur les saisies manuelles incluent l'exigence d'autorisations avant la saisie et après une vérification, l'utilisation de formulaires prénumérotés concis et la formation du personnel de saisie des données.

Les aides électroniques pour les entrées manuelles incluent les formats d'écran faciles d'utilisation qui demandent aux utilisateurs des informations requises et l'utilisation de champs obligatoires. Une vérification de champ consiste à vérifier si les informations d'un champ de saisie sont exhaustives. Les menus déroulants et les fonctions similaires ne permettent que des entrées prédéfinies spécifiques. Pour protéger les informations sensibles, la vérification des frappes requiert que les données soient saisies deux fois, par différentes personnes si possible, et met en évidence les différences. Les étiquettes de fichiers et les conventions d'étiquetage identifient les enregistrements ou transactions corrects.

Les contrôles par lots accumulent les transactions, puis appliquent des tests au lot, par exemple, un total de contrôle. Le total de contrôle est rapproché au niveau de différents points de transfert. Les systèmes en temps réel ne peuvent pas utiliser les contrôles par lots et doivent se baser sur une vérification visuelle. Par exemple, une fois qu'un numéro de fournisseur est saisi, le système peut afficher le nom du fournisseur et demander une vérification.

Les contrôles de correction d'erreurs de saisie sont problématiques car une erreur existe déjà et la correction pourrait provoquer des erreurs supplémentaires. Les auditeurs internes doivent attentivement vérifier les rapports d'erreur avant de décider quoi faire. Une fois la décision prise, les fichiers sont mis à jour avec les nouvelles entrées et les soldes sont ajustés.

b. Contrôles d'entrée par lots

- **Les totaux financiers** résument les montants monétaires dans un champ d'information d'un groupe d'enregistrements. Le total produit par le système après le traitement du lot est comparé au total produit manuellement au préalable.
- **Le nombre d'enregistrements** suit le nombre d'enregistrements traités par le système à des fins de comparaison avec le nombre d'enregistrements que l'utilisateur s'attendait à voir traités.
- **Les totaux de hachage** sont des totaux de contrôle sans signification définie, tels que le total des numéros de fournisseur ou des numéros de facture, qui sont utilisés pour vérifier l'intégralité des données.
- **Version de gestion**. Un lot n'est pas validé pour traitement tant qu'un responsable n'a pas été revu et approuvé.

EXEMPLE

Une entreprise a les factures suivantes dans un lot:

N° de facture	Produit	Quantité	PU
303	G7	100	15 $ US
305	A48	200	5
353	L30	125	10
359	Z26	150	20

Le total de hachage est un total de contrôle sans signification définie, tel que le total des numéros d'employé ou le total des factures, utilisé pour vérifier l'exhaustivité des données. En utilisant les numéros de facture, le total de hachage serait de 1320.

c. Contrôles d'entrée en ligne ou en temps réel

- Le **pré-formatage** des écrans de saisie de données, c'est-à-dire leur imitation de la mise en page d'un formulaire imprimé, peut aider l'opérateur à saisir les bons champs.
- Les **contrôles de format**. Il s'agit de vérifications pour déterminer si les données sont saisies dans un format acceptable, par exemple, une date est saisie au format mm/jj/aaaa et non au format mm/jj/aa (ou en Europe, jj/mm/aaaa).
- Les **contrôles d'édition**. Il s'agit de tests automatisés appliqués aux champs de données. Certains de ces contrôles peuvent également être considérés comme des contrôles de traitement.

- **Les contrôles de validité** comparent les données saisies dans une zone donnée avec une table des valeurs valables pour cette zone. Par exemple, le numéro de fournisseur d'une demande de réduction de chèque doit correspondre à la table des fournisseurs actuels et le numéro de facture doit correspondre à la table de facture approuvée.
- **Les contrôles de limites (raison) et de Plages de test** sont basés sur les limites connues de l'information donnée. Par exemple, le nombre d'heures travaillées par semaine doit se situer entre 0 et 100, et tout ce qui dépasse cette fourchette doit être autorisé par la direction.
- **Chiffres de contrôle.** Un chiffre supplémentaire est ajouté. Il est lié par un algorithme aux chiffres restants et permet de déterminer si le nombre a été saisi de manière incorrecte par transposition. Il est utilisé pour les cartes de crédit.
- **Les contrôles de séquence** sont basés sur la logique selon laquelle l'efficacité du traitement est considérablement accrue lorsque les fichiers sont triés sur un champ désigné, appelé "clé", avant des opérations telles que la comparaison. Si le système découvre qu'un document n'est pas en ordre, il peut indiquer que les dossiers n'ont pas été correctement préparés pour le traitement.
- **Les contrôles de solde nul** rejetteront toute transaction ou tout lot de transactions dans lequel la somme de tous les débits et crédits n'est pas égale à zéro.
- **La vérification en boucle fermée** se produit lorsque les entrées d'un utilisateur sont transmises à l'ordinateur, traitées et affichées en retour à l'utilisateur pour vérification.

d. Les contrôles du traitement

Ils fournissent une assurance raisonnable que (1) toutes les données soumises pour traitement sont traitées et (2) seules les données approuvées sont traitées. Ces contrôles sont intégrés au code de l'application par les programmeurs pendant le processus de développement des systèmes.

- Certains contrôles de traitement répètent les étapes exécutées par les **contrôles d'entrée**, telles que les contrôles de limites et les contrôles par lots.
- **Les contrôles simultanés** gèrent les situations où deux utilisateurs ou plus tentent d'accéder ou de mettre à jour un fichier ou une base de données simultanément. Ces contrôles garantissent que les résultats corrects sont générés tout en obtenant ces résultats le plus rapidement possibles.
- **Validation.** Les identificateurs sont comparés aux fichiers maîtres pour déterminer l'existence. Par exemple, toute opération de comptes fournisseurs pour laquelle le numéro fournisseur ne correspond pas à un numéro figurant dans le fichier de base fournisseur est rejetée.
- **Complétude.** Tout enregistrement pour lequel il manque des données est rejeté.

- **Contrôles arithmétiques.** Le contrôle croisé compare un montant avec la somme de ses composantes. La vérification du solde nul ajoute les débits et les crédits d'une transaction ou d'un lot pour s'assurer que leur total est nul.
- **Contrôle de séquence.** L'effort informatique est le plus efficace lorsque les données sont traitées dans un ordre logique, par exemple par numéro de client. Cette vérification permet de s'assurer que le lot est trié dans l'ordre approprié avant le début du traitement.
- **Totaux de contrôle d'exécution à exécution.** Les contrôles associés à un lot donné sont vérifiés après chaque étape du traitement pour s'assurer que toutes les transactions ont été traitées.
- **Contrôle d'intégrité de clé.** La clé d'un enregistrement est le groupe de valeurs dans des zones désignées qui identifient de façon unique l'enregistrement. Aucun processus de demande ne devrait pouvoir modifier les données de ces champs clés.

e. Les contrôles de sortie

Ils fournissent l'assurance que le résultat du traitement (comme les listes ou les affichages de comptes, les rapports, les fichiers, les factures ou les chèques de déboursement) est exact et que seul le personnel autorisé reçoit le résultat.

Les contrôles sur les sorties sont des contrôles de détection qui détectent des erreurs et vérifient la précision et la vraisemblance des données de sortie une fois le traitement terminé. Exiger des utilisateurs qu'ils vérifient immédiatement la sortie de leur travail est le contrôle sur les sorties le plus basique et le plus essentiel car les utilisateurs disposent des meilleures connaissances sur le processus à ce moment donné. Trois totaux peuvent être rapprochés. L'auditeur peut générer manuellement des échantillons de total de contrôle et les comparer aux entrées et aux sorties du système. De la même manière, une comparaison automatisée des entrées et des sorties peut révéler des relations invraisemblables. Les formulaires de sortie prénumérotés, notamment les blancs de chèque, montrent les écarts de sortie de contrôle.

La conservation des enregistrements est un contrôle sur les sorties confirmées par la loi ou les règlements, en particulier pour les enregistrements financiers. D'autres enregistrements peuvent être stockés de manière électronique. Les procédures de sauvegarde des données peuvent assurer leur sécurité. Ces procédures sont exécutées à la fin du traitement afin de s'assurer que toutes les transactions que l'utilisateur s'attendait à traiter ont bien été traitées. Voici les contrôles sur les sorties :

- Les **listes d'erreurs**. Toutes les transactions rejetées par le système sont enregistrées et distribuées au service approprié pour résolution. Les auditeurs vérifient que les erreurs sont suivies sans dépasser les limites de retard et que les rapports corrigés sont à nouveau soumis.
- Les **documents de référence**. Lorsque les systèmes sont interrompus, ces journaux montrent ce qui était en mémoire au moment de l'interruption.

- Les **contrôles de mise en file d'attente**. La mise en file d'attente est une allocation de mémoire temporaire à une sortie système. Ces contrôles régulent les méthodes de mise en file d'attente des données.
- Les **documents de travail**. Les enregistrements légaux, notamment les chèques, les factures ou les certificats de stock, sont protégés. Il s'agit de preuves d'audit qui peuvent détecter si les entrées correspondent réellement aux sorties. Le double dépôt ou nécessité que deux personnes accèdent aux enregistrements est utilisé pour les obligations, les chèques ou les paies.
- **Rapports.** Les contrôles de rapport incluent la vérification que les rapports sont précis, aussi simples que possible, opportuns, agrégés à un niveau significatif et que les données sensibles sont sécurisées à l'aide de contrôles de distribution.
- Les **listes de contrôles** assurent la réception de tous les rapports planifiés et les listes de rapports récapitulent les rapports traités par lots. Les rapports sensibles doivent être déchiquetés.
- **Rapports d'exception** En mettant en évidence uniquement les données extraordinaires, les rapports d'exception liés à la sortie doivent aider les responsables à déterminer la source d'erreur (erreur humaine, erreur de traitement, etc.).
- **Les relevés de transactions.** Chaque action effectuée dans l'application est enregistrée avec la date, l'heure et l'ID utilisés lorsque l'action a été effectuée.
- **Nombre d'enregistrement.** Le nombre total d'enregistrements traités par le système est comparé au nombre d'enregistrements que l'utilisateur s'attendait à voir traités.
- **Totaux de contrôle d'exécution à exécution.** Le nouveau solde financier doit être la somme de l'ancien solde et de l'activité qui vient d'être traitée.

f. Les contrôles d'intégrité

Ils surveillent les données au fur et à mesure de leur traitement et lors de leur stockage pour vérifier qu'elles restent cohérentes et exhaustives. Les dossiers spécifiques doivent être uniques ce qui signifie qu'ils ne doivent pas être dupliqués ou enregistrés sous un nom légèrement différent. Les contrôles d'intégrité sont appliqués à la base de données et au système de gestion de base de données (DBMS, « Data base management system ») afin que ces contrôles varient selon le type de système de gestion de base de données utilisé. Les contrôles d'intégrité des bases de données relationnelles sont les suivants :

- **Clés primaires uniques**. La clé primaire, ou identifiant pour une ligne de données spécifique, doit être unique; par exemple on comptera exactement un seul dossier pour un client XZ.
- **Clés primaires complètes**. La clé primaire ne peut pas contenir de valeur nulle.

- **Intégrité référentielle**. Lorsqu'une table de base de données (appelée relation) contient une référence à une colonne (appelé un tuple) dans la table ou dans une autre table, cette colonne doit être vérifiée pour qu'elle puisse exister.

g. Les pistes d'audit ou de gestion

Ils fournissent un historique de tous les traitements de transactions, qui présente chaque étape, de l'interception à la conclusion. Cela permet à un auditeur de suivre une transaction en amont, de la sortie à sa source. Cela peut être utile lors de l'identification de la source d'erreur ou de fraude.

6. Classification basée sur le temps

Les contrôles de rétroaction rapportent l'information sur les activités terminées. Ils permettent d'améliorer les performances futures en tirant les leçons des erreurs passées. Par exemple, l'inspection des marchandises terminées, suivie de procédures d'analyse des écarts, permet de déceler les écarts par rapport à ce qui était prévu. Ainsi, l'inspection et l'analyse des écarts fournissent une rétroaction sur la mesure dans laquelle l'achèvement des marchandises répond aux attentes.

Les contrôles simultanés ajustent les processus en cours. Ces contrôles en temps réel surveillent les activités en cours pour éviter qu'elles ne s'éloignent trop des normes. Un exemple en est la surveillance étroite des travailleurs de la chaîne de production.

Les contrôles anticipés anticipent et préviennent les problèmes. Ces contrôles exigent une perspective à long terme. Les politiques et procédures organisationnelles en sont des exemples.

7. Contrôles financiers et contrôles d'exploitation

Les contrôles financiers devraient être fondés sur les principes comptables établis pertinents. Les objectifs des contrôles financiers peuvent inclure (a) une autorisation appropriée ; (b) la tenue de registres appropriés ; (c) la protection des biens ; et (d) le respect des lois, des règlements et des contrats.

Les contrôles d'exploitation s'appliquent aux activités de production et de soutien. Parce qu'ils peuvent manquer de critères ou de normes établis, ils devraient être fondés sur des principes et des méthodes de gestion. Ils devraient également être conçus en fonction des fonctions de gestion de la planification, de l'organisation, de la direction et du contrôle.

8. Contrôles axés sur les personnes et contrôles axés sur les systèmes

Les contrôles humains dépendent de l'intervention de l'homme pour leur bon fonctionnement, par exemple, l'exécution régulière des rapprochements bancaires. Les listes de contrôle, telles que les listes des procédures requises pour la clôture mensuelle, peuvent être utiles pour s'assurer que les contrôles basés sur les personnes sont exécutés au besoin.

Les contrôles basés sur le système sont exécutés chaque fois que nécessaire, sans intervention humaine. Un exemple est le code d'un système d'achat informatisé qui empêche toute commande supérieure à un certain seuil monétaire d'être soumise au vendeur sans l'approbation de la direction.

9. Utilisation d'une matrice de contrôle

Les contrôles ne correspondent pas nécessairement aux risques pris individuellement. Certains contrôles peuvent porter sur plus d'un risque et plus d'un contrôle peut être nécessaire pour traiter adéquatement un seul risque. Par exemple, supposons que tous les responsables de la petite caisse doivent présenter périodiquement des pièces justificatives de dépenses. Ce contrôle permet de s'assurer a) que les comptes de petite caisse sont maintenus au niveau établi et b) que les dépenses de petite caisse sont examinées pour déterminer si elles sont appropriées. Une matrice de contrôle est utile pour faire correspondre les contrôles aux risques dans ces circonstances.

Control Matrix

	Control A	Control B	Control C	Control D
Risk 1	●			
Risk 2	●			
Risk 3		●		
Risk 4		●	●	
Risk 5	●			
Risk 6				●

Figure 5-1

III. CADRES DE CONTRÔLE

1. Cadres de contrôle disponibles

Plusieurs organes ont publié des cadres de contrôle qui fournissent un moyen complet de s'assurer que l'organisation a pris en compte tous les aspects pertinents du contrôle interne. L'utilisation d'un modèle particulier ou d'une conception de commande non mentionnée ici peut être spécifiée par des exigences réglementaires ou légales. Certains des cadres les plus connus sont décrits à la page suivante.

a. États-Unis

Les enquêtes du Watergate de 1973-1974 ont révélé que des entreprises américaines soudoyaient des fonctionnaires, des politiciens et des partis politiques dans des pays étrangers. Il en a résulté la loi de 1977 sur les pratiques de corruption à l'étranger (Foreign Corrupt Practices Act).

Le secteur privé a également réagi en créant la Commission nationale des rapports financiers frauduleux (NCFFR) en 1985. La NCFFR est connue sous le nom de Commission Treadway parce que James C. Treadway en a été le premier président. À l'origine, la Treadway Commission était parrainée et financée par cinq organismes comptables professionnels établis aux États-Unis. Ce

groupe de cinq personnes est devenu le Committee of Sponsoring Organizations of the Treadway Commission (COSO). La Commission a recommandé que ce groupe de cinq organisations coopère à l'élaboration de directives en matière de contrôle interne.

Le résultat en a été le COSO *Internal Control - Integrated Framework*, publié en 1992, qui a été modifié en 1994 et de nouveau en 2013.

b. Canada

Guidance on Control (communément appelé CoCo d'après son titre original *Criteria of Control*), publié par l'Institut Canadien des Comptables Agréés (ICCA).

c. Royaume-Uni

Contrôle interne : Guidance for Directors on the Combined Code (communément appelé Rapport Turnbull en l'honneur de Nigel Turnbull, président de la commission qui a rédigé le rapport), publié par le Financial Reporting Council (FRC) du Royaume-Uni et réédité sous le titre *Internal Control : Guide révisé à l'intention des administrateurs sur le Code combiné*. Le UK Committee on the Financial Aspects of Corporate Governance (connu officieusement sous le nom de Cadbury Committee, du nom de son président Sir Adrian Cadbury) a publié son rapport à peu près en même temps que la Treadway Commission aux États-Unis. Il a par la suite été fusionné avec les rapports de deux autres organisations. Le *code combiné* qui en résulte contient des recommandations pour une saine gouvernance, comme l'exigence que le chef de la direction et le président du conseil soient des personnes distinctes.

d. Technologies de l'information

Control *Objectives for Information and Related Technology* (COBIT) est le cadre le plus connu pour les contrôles informatiques. COBIT 5 est la version la plus récente.

Le cadre COBIT 5 couvre le cadre informatique VAL. Il traite de la gouvernance des investissements opérationnels axés sur la TI. Electronic *Systems Assurance and Control* (eSAC), publié par The Institute of Internal Auditors Research Foundation, est un modèle de contrôle alternatif pour les TI.

2. Cadre du COSO

a. Définition du contrôle interne

Le modèle COSO définit le contrôle interne comme suit :

> *Le contrôle interne est un processus, mis en œuvre par le conseil d'administration, la direction et les autres membres du personnel de l'entité, qui vise à fournir une assurance raisonnable quant à l'atteinte des objectifs en matière d'exploitation, d'information et de conformité.*

Ainsi, le contrôle interne est

- Destiné à atteindre trois catégories d'objectifs
- Un processus continu

- Les personnes de tous les niveaux de l'organisation, p. ex. le conseil d'administration, la direction et tous les autres employés, ont des répercussions sur les activités de l'organisation.
- Capable de fournir une assurance raisonnable, mais non absolue
- Adaptable à la structure de l'entité

b. **Les objectifs**

Les trois catégories d'objectifs orientent les organisations vers les différents éléments de contrôle (mais qui se chevauchent).

- **Opérations.**

Les objectifs opérationnels ont trait à la réalisation de la mission de l'entité. Les objectifs appropriés comprennent l'amélioration (1) du rendement financier, (2) de la productivité, (3) de la qualité, (4) de l'innovation et (5) de la satisfaction des clients.

Les objectifs opérationnels comprennent également la **protection des biens**. Les objectifs liés à la protection et à la préservation des biens aident à l'évaluation des risques et à l'élaboration de contrôles d'atténuation. Éviter le gaspillage, l'inefficacité et les mauvaises décisions d'affaires ont trait à des objectifs plus larges que la protection des actifs.

- **Reporting**

Pour prendre des décisions éclairées, les intervenants doivent disposer d'une information financière fiable, opportune et transparente. Des rapports peuvent être préparés à l'intention de l'organisation et des intervenants. Les objectifs peuvent porter sur :

- ✓ Rapports financiers et non financiers
- ✓ Reporting interne ou externe

- **Conformité**

Les entités sont assujetties à des lois, des règles et des règlements qui établissent des normes minimales de conduite. Par exemple, la fiscalité, la protection de l'environnement et les relations avec les employés. Le respect des politiques et procédures internes est une question opérationnelle.

Ce qui suit est un aide-mémoire utile pour les catégories d'objectifs du COSO :

O = Opérations **R** = Rapports **C** = Conformité

Atteinte des objectifs.

Un système de contrôle interne est plus susceptible de fournir une assurance raisonnable de l'atteinte des objectifs de déclaration et de conformité que les objectifs opérationnels. Les objectifs de déclaration et de conformité sont des réponses aux normes établies par des parties externes, comme les organismes de réglementation. Par conséquent, la réalisation de ces objectifs dépend presque entièrement des actions qui sont sous le contrôle de l'entité.

Cependant, l'efficacité opérationnelle peut ne pas être sous le contrôle de l'entité parce qu'elle est affectée par le jugement humain et de nombreux facteurs externes.

c. Composantes du contrôle interne

Les cinq composantes suivantes du contrôle interne appuient l'organisation dans ses efforts pour atteindre ses objectifs :

- Environnement de contrôle
- Évaluation des risques
- Activités de contrôle
- Information et communication
- Surveillance

Une aide-mémoire utile pour les composants COSO du contrôle interne est "Controls stop **CRIME**".

- **C** = Activités de contrôle
- R = Évaluation des risques
- I = Information et communication
- M = Surveillance
- E = Environnement de contrôle

d. Environnement de contrôle

L'environnement de contrôle est un ensemble de normes, de processus et de structures qui affectent de façon envahissante le système de contrôle interne. Cinq principes concernent l'environnement de contrôle. L'organisation fait preuve d'un engagement envers l'**intégrité et les valeurs éthiques** en :

- Donnant le ton au sommet. Par leurs paroles et leurs actes, le conseil d'administration et la direction communiquent leur attitude envers l'intégrité et les valeurs éthiques.
- Établissant des normes de conduite. Le conseil et la direction créent des attentes qui doivent être comprises à tous les niveaux de l'organisation et par les fournisseurs de services et les partenaires commerciaux externes.
- Évaluant le rendement des personnes et des équipes en fonction des normes de conduite établies.
- Corrigeant les écarts en temps opportun et de façon uniforme.

Le **conseil** fait preuve d'indépendance à l'égard de la direction et exerce une **surveillance** en matière de contrôle interne. Le conseil :

- Établit les responsabilités en matière de surveillance. Le conseil identifie et accepte ses responsabilités de surveillance.

- Appliquer l'expérience pertinente en définissant, en maintenant et en évaluant périodiquement les compétences et l'expertise nécessaires parmi ses membres pour poser des questions difficiles à la direction et prendre les mesures appropriées.
- Agir de façon indépendante. Le conseil d'administration comprend un nombre suffisant de membres indépendants et objectifs qui participent aux évaluations et à la prise de décisions. Par exemple, dans certaines administrations, tous les membres du comité de vérification doivent être des administrateurs externes.
- Assure la surveillance. Le conseil est chargé de superviser la conception, la mise en œuvre et la conduite du contrôle interne par la direction.

La direction établit, sous la supervision du conseil, les **structures, la structure hiérarchique et les pouvoirs et responsabilités appropriés**. La Direction

- Tient compte de toutes les structures de l'entité. Les variables prises en compte dans l'établissement des structures organisationnelles sont les suivantes :
  - ✓ Nature de l'activité
  - ✓ Taille et périmètre géographique de l'entité
  - ✓ Risques, dont certains externalisés, et liens avec des prestataires de services et partenaires extérieurs
  - ✓ Attribution de l'autorité à différents niveaux de gestion
  - ✓ Définition des lignes hiérarchiques
  - ✓ Exigences en matière de rapports
- Établit et évalue les voies hiérarchiques. La tendance en matière de gouvernance d'entreprise a été de permettre aux employés de prendre des décisions plus près de leurs activités quotidiennes.
- Conçoit, attribue et limite les pouvoirs et les responsabilités.

L'organisation fait preuve d'un **engagement à attirer, à perfectionner et à maintenir en poste des personnes compétentes** conformément à ses objectifs.

- Les politiques et les pratiques reflètent les attentes en matière de compétence. Le contrôle interne est renforcé lorsque la direction précise les compétences requises pour des postes particuliers.
- Le conseil d'administration et la direction évaluent les compétences et comblent les lacunes. Les employés et les fournisseurs de services externes possèdent les compétences et les connaissances appropriées pour effectuer leur travail.
- L'organisation attire, développe et retient les individus. L'organisation s'engage à embaucher des personnes compétentes et intègres. Une formation et un mentorat continus sont nécessaires pour adapter les employés aux exigences de contrôle d'un environnement en évolution.

- La direction générale et le conseil planifient et préparent la relève.

L'**organisation tient les personnes responsables de** leurs responsabilités en matière de contrôle interne dans la poursuite des objectifs. La direction et le conseil

- Faire respecter l'obligation de rendre compte au moyen de structures, de pouvoirs et de responsabilités
- Établir des mesures de rendement, des incitatifs et des récompenses
- Évaluer les mesures de rendement, les incitatifs et les récompenses pour leur pertinence continue
- Tenir compte des pressions excessives
- Évaluer le rendement et récompenser ou discipliner les personnes

e. **Évaluation des risques**

Le processus d'évaluation des risques comprend une évaluation des risques eux-mêmes et de la nécessité de gérer le changement organisationnel. Ce processus sert de base pour déterminer comment les risques devraient être gérés. Quatre principes ont trait à l'évaluation des risques.

L'organisation **précise les objectifs** avec suffisamment de clarté pour permettre l'identification et l'évaluation des risques liés à cinq types d'objectifs.

- Opérations
- Rapports financiers externes
- Rapports non financiers externes
- Rapports internes
- Conformité

L'organisation **détermine les** risques qui compromettent l'atteinte de ses objectifs dans l'ensemble de l'entité et **analyse les** risques afin de déterminer comment ils devraient être gérés. La direction doit se concentrer attentivement sur les risques à tous les niveaux de l'entité et prendre les mesures nécessaires pour les gérer.

L'organisation tient compte de la possibilité de fraude dans l'**évaluation des risques de fraude liés à l'**atteinte des objectifs. L'organisation doit

- examiner divers types de fraude,
- évaluer les incitatifs et les pressions,
- évaluer les possibilités et
- évaluer les attitudes et les rationalisations.

L'organisation **identifie et évalue les changements** qui pourraient affecter de manière significative le système de contrôle interne. Des changements importants pourraient survenir dans

l'environnement externe, le modèle opérationnel et le leadership d'une organisation. Les contrôles internes doivent donc être adaptés à l'évolution de la situation de l'entité.

f. **Activités de contrôle**

Ces politiques et procédures permettent de s'assurer que les directives de gestion sont respectées. Qu'elles soient automatisées ou manuelles, elles sont appliquées à différents niveaux de l'entité et aux différentes étapes des processus. Ils peuvent être préventifs ou détectives, et la séparation des tâches est habituellement présente. Trois principes ont trait aux activités de contrôle.

- L'organisation choisit et élabore des activités de contrôle qui contribuent à l'**atténuation des risques en vue d'**atteindre les objectifs à des niveaux acceptables.
- L'organisation choisit et élabore des activités générales de contrôle de la **technologie** pour appuyer l'atteinte des objectifs.
- L'organisation déploie des activités de contrôle au moyen de **politiques** qui établissent ce qui est attendu et de **procédures** qui mettent les politiques en application.

g. **Information et communication**

Les systèmes d'information permettent à l'organisation d'obtenir, de produire, d'utiliser et de communiquer de l'information pour (a) maintenir la responsabilisation et (b) mesurer et examiner le rendement. Trois principes ont trait à l'information et à la communication.

- L'organisation obtient ou génère et utilise une **information pertinente et de qualité** pour appuyer le fonctionnement du contrôle interne.
- L'organisation **communique à l'interne l'**information, y compris les objectifs et les responsabilités en matière de contrôle interne, nécessaire pour appuyer la fonction de contrôle interne.
- L'organisation **communique avec les parties externes au** sujet des questions touchant le fonctionnement du contrôle interne.

h. **Activités de surveillance**

Les systèmes de contrôle et la façon dont les contrôles sont appliqués changent avec le temps. La surveillance est un processus qui permet d'évaluer la qualité du rendement du contrôle interne au fil du temps pour s'assurer que les contrôles continuent de répondre aux besoins de l'organisation. Voici deux principes liés aux activités de surveillance :

- L'organisation choisit, élabore et effectue des **évaluations continues ou distinctes (ou les deux)** pour déterminer si les composantes du contrôle interne sont présentes et fonctionnent.
- L'organisation **évalue et communique les lacunes de contrôle en** temps opportun.

Les changements dans l'environnement externe ou interne créent des risques pour le système de contrôle interne de l'organisation. Pour s'assurer que le système de contrôle interne demeure

capable d'atteindre ses objectifs, l'organisation devrait maintenir un programme de surveillance efficace. Les étapes du continuum de la surveillance du changement sont les suivantes :

- **Base de référence du contrôle**. La surveillance doit commencer par la compréhension de la conception du contrôle interne et de l'efficacité des contrôles mis en place pour atteindre les objectifs de l'organisation. Cette compréhension de base du contrôle interne fournit un point de départ pour faire des suggestions sur la façon d'améliorer l'efficience et l'efficacité.
- **Identification des changements.** Une évaluation continue ou distincte (ou les deux) est utilisée pour déterminer si des changements au processus ou des risques sont pris en compte. Dans le cadre de ces évaluations, l'organisation devrait confirmer que les contrôles continuent d'atteindre leurs objectifs qui consistent à aider à gérer ou à atténuer les risques connexes.
- **Gestion du changement**. L'organisation devrait vérifier que le système de contrôle interne gère les changements et établit une nouvelle base de contrôle pour les contrôles modifiés.
- **Revalidation des contrôles.** La revalidation des contrôles est le processus qui consiste à utiliser des procédures de surveillance pour confirmer la conclusion que les contrôles sont efficaces. Il s'agit d'une forme de surveillance continue.

Relation entre les objectifs, les composantes et la structure organisationnelle.

Le modèle COSO peut être affiché sous la forme d'un cube avec des lignes, des tranches et des colonnes. Les rangées sont les cinq composantes, les tranches sont les trois objectifs, et les tranches sont les trois objectifs.

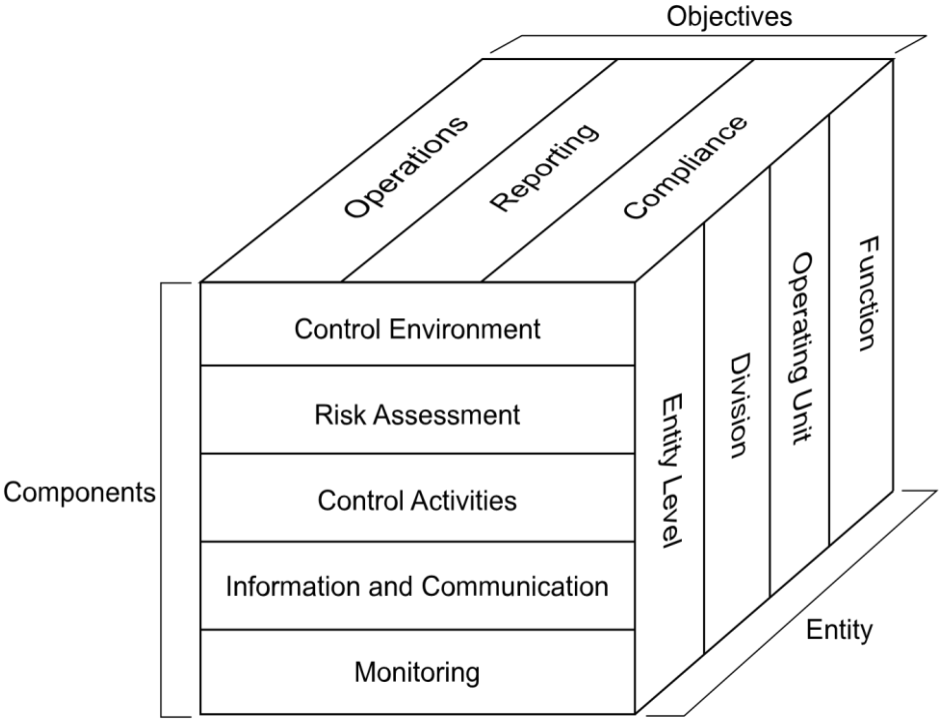

Figure 5-2

3. Modèle CoCo

Le modèle du CoCo est considéré comme étant mieux adapté à l'audit interne. Il se compose de 20 critères regroupés en 4 composantes :

- Objet
- Engagement
- Capacité
- Surveillance et apprentissage

Ce qui suit est un aide-mémoire utile pour les composantes du modèle CoCo :

P = Objet	Police
C = Engagement	Canette
C = Capacité	Attraper
M = Surveillance	Beaucoup
L = Apprentissage	Les contrevenants à la loi

4. COBIT -- Un cadre pour la gouvernance et la gestion des TI

COBIT est le cadre de contrôle et de gouvernance le plus connu en matière de technologie de l'information. Dans sa version originale, COBIT se concentrait sur les contrôles de processus informatiques spécifiques. Au fil des ans, la technologie de l'information s'est progressivement répandue dans tous les aspects des activités de l'organisation. La TI ne peut plus être considérée comme une fonction distincte des autres aspects de l'organisation. L'évolution de COBIT a reflété ce changement dans la nature de la TI au sein de l'organisation.

5. COBIT 5 -- Un cadre pour la gouvernance et la gestion des TI

a. Cinq principes clés

- **Principe 1 : Répondre aux besoins des parties prenantes.** Les besoins des parties prenantes permettent de créer de la valeur dans une organisation. Puisque l'objectif du gouvernement d'entreprise est de créer de la valeur dans une organisation, le gouvernement d'entreprise doit définir la création de valeur comme la réalisation des avantages selon les attentes des parties prenantes, tout en optimisant l'utilisation des ressources et la gestion des risques.

  Les besoins des parties prenantes sont souvent incompatibles. Par exemple, d'un côté le besoin des parties prenantes peut se centrer sur les profits et de l'autre on peut faire face aux exigences de la réglementation ou de la société en matière de durabilité environnementale. Par conséquent, le cadre de référence COBIT 5 met en avant le gouvernement d'entreprise car il favorise un processus de négociation au niveau des

intérêts de valeur pour les parties prenantes et permet ensuite de décider comment créer une valeur optimale pour les parties prenantes au niveau global.

De plus, puisqu'il s'agit d'un cadre générique, la notion de valeur peut varier considérablement en fonction des parties prenantes (par exemple une organisation à but lucratif et une organisation sans but lucratif). Pour aider les organisations à établir ce qui peut apporter de la valeur, le cadre de référence COBIT 5 comprend des valeurs en cascade ; en d'autres termes il s'agit d'un ensemble de tables qui commence par présenter un ensemble de 17 objectifs génériques comme par exemple, « la transparence financière ». Les organisations sélectionnent des objectifs génériques dans cette table qui descendent en cascade vers 17 objectifs informatiques comme par exemple, « la transparence des coûts, les avantages et les risques liés à l'informatique », qui à leur tour descendent en cascade vers un ensemble d'objectifs de mise en œuvre. Les objectifs de mise en œuvre représentent les objectifs des processus de mise en œuvre du cadre de référence COBIT 5 comme par exemple les personnes, le savoir et les compétences. Le but est de traduire les besoins des parties prenantes et les objectifs dérivés de gouvernement d'entreprise en priorité pondérée relative aux objectifs informatiques et, à partir de là, exécuter facilement les processus, les politiques et les procédures.

- **Principe 2 : Couvrir l'entreprise de bout en bout.** Le second principe établit que le gouvernement d'entreprise relatif aux systèmes informatiques doit faire partie intégrante du gouvernement d'entreprise global de l'organisation et du cadre de contrôle interne. Le cadre de référence COBIT 5 intègre la plupart des modèles et concepts actuels de gouvernement d'entreprise. Il s'applique également aux processus qui ont été sous-traités ou qui font partie d'un groupe d'entreprises partenaires dans la chaîne d'approvisionnement. Les sept principes de mise en œuvre énumérés précédemment sont à l'échelle de l'organisation au niveau du périmètre donc le fait de se concentrer sur chacun de ces catalyseurs permet de disposer d'un gouvernement d'entreprise de bout en bout. La dernière partie de ce principe implique de définir les rôles du gouvernement d'entreprise ainsi que ses relations et activités. Les propriétaires ou les parties prenantes délèguent à un organe de direction (par exemple le conseil d'administration) qui communique les lignes directrices à la direction; la direction fournit ensuite des instructions au service des opérations afin que celui-ci s'aligne sur les objectifs de partie prenantes. Chaque relation comprend également un processus de feedback pour le reporting, le suivi et la responsabilité.
- **Principe 3 : Appliquer un référentiel unique et intégré.** Le cadre de référence COBIT 5 a été conçu pour qu'il puisse s'intégrer facilement au niveau d'autres cadres de gouvernement d'entreprise pour fournir une source unique de recommandations organisationnelles. Le cadre ne s'attarde pas sur les détails techniques et intègre tous les conseils de l'ISACA publiés antérieurement et est conçu pour s'intégrer avec d'autres cadres de gouvernement d'entreprise comme la norme ISO/IEC 38500 que nous verrons plus loin dans cette rubrique.

- **Principe 4 : Faciliter une approche globale.** Les sept catalyseurs énumérés précédemment sont utilisés pour mettre en œuvre chaque objectif fixé en utilisant une approche descendante. Le premier catalyseur qui englobe « principes, politiques et référentiels » est central ; il fournit des conseils pratiques sur la manière de façonner un comportement souhaité en réalisant des activités de gestion spécifiques. Les processus; les structures organisationnelles; et la culture, le code de déontologie et les principes touchant au comportement sont des activités de gestion axées sur le gouvernement d'entreprise de l'organisation qui permettent d'assurer que les principes, politiques et cadres sont adoptés. Le gouvernement d'entreprise exerce un pouvoir d'orientation sur la culture, le code de déontologie et le comportement afin d'assurer que les objectifs sont réalisés même si son influence est souvent sous-estimée. Les autres principes liés à l'information; les services, les infrastructures et les applications; et les personnes, le savoir et les compétences sont des catalyseurs permettant la gestion des ressources conformément aux principes de base et au cadre. Ces catalyseurs sont interconnectés et dépendent les uns des autres pour être efficace. Par exemple, les processus ont besoin d'informations, de compétences et d'un comportement adéquats pour qu'ils soient efficaces et efficients.

  Le cadre de référence COBIT 5 dispose d'un ensemble de dimensions pour chaque catalyseur qui permet d'assurer que chacun des éléments suivants est pris en compte pour chaque catalyseur :

  - ✓ Est-ce que la mesure des indicateurs avancés (métriques prédictives) montre que les entrées, pratiques et sorties ont été effectuées correctement ?
  - ✓ Est-ce que la mesure des indicateurs avancés montre que le bon cycle de développement de systèmes a été utilisé (par exemple, les feedbacks ont-ils été pris en compte) ?
  - ✓ Est-ce que la mesure des indicateurs retardés (métriques historiques) montre que les exigences des parties prenantes internes et externes ont été respectées ?
  - ✓ Est-ce que la mesure des indicateurs retardés montre que les objectifs de mise en œuvre ont été réalisés (par exemple la qualité, l'efficacité, l'efficience, la sécurité, l'accessibilité) ?

- **Principe 5 : Distinguer la gouvernance de la gestion.** L'organe de gouvernement d'entreprise d'une organisation, généralement son conseil d'administration, doit se différencier entièrement de la direction. Le cadre de référence COBIT 5 présente cinq processus de gouvernement d'entreprise et 32 processus de gestion qui ont été développés en détail dans un document de support intitulé «COBIT 5: Enabling Processes. » Pour chaque processus de gouvernement d'entreprise, les rôles principaux sont d'évaluer, diriger et de contrôler. Les processus de gouvernement d'entreprise consisteront entre autres à s'assurer que le cadre de gouvernement d'entreprise est en place et maintenu, que les avantages sont communiqués aux parties prenantes, que les réponses au risque sont optimisés, que l'utilisation des ressources est optimisée et que la transparence est garantie.

Les processus de gestion sont répartis dans les catégories suivantes qui reflètent un ensemble cyclique des rôles de gestion :

- ✓ **Aligner, planifier et organiser**. Les processus comportent la stratégie de gestion, l'infrastructure des systèmes, le risque, la sécurité, les ressources humaines et les relations.
- ✓ **Construire, acquérir et mettre en œuvre**. Les processus comportent la gestion de projet et du changement, la définition des exigences, l'identification et la mise en place de solutions et la gestion de la configuration, des changements, des connaissances et des actifs.
- ✓ **Fourniture, service et soutien**. Les processus comportent la gestion des opérations, des incidents et des problèmes, la continuité, la sécurité et les contrôles de processus.
- ✓ **Surveiller, étudier et évaluer**. Les processus comportent le suivi, l'évaluation, l'évaluation de la performance et de la conformité, l'infrastructure de contrôle et la conformité aux exigences externes.

Le cadre de référence COBIT 5 et ses produits connexes peuvent, dans leur ensemble, aider les organisations à optimiser leurs investissements dans les système d'informations en établissant un équilibre optimal entre la communication des avantages aux parties prenantes, la gestion efficace des risques et une gestion efficace de l'utilisation des ressources.

6. VAL IT

VAL IT est basé sur COBIT et le complète. Son objectif est d'établir les meilleures pratiques qui contribuent au processus de création de **valeur.** Il mesure, surveille et maximise la réalisation de la valeur commerciale de l'investissement dans les TI. Selon l'Information Systems Audit and Control Association (ISACA), le cadre informatique VAL comprend les trois domaines suivants :

- Gouvernance des valeurs. Ce domaine définit la relation entre la TI et l'organisation, ce qui comprend les fonctions de l'organisation ayant des responsabilités de gouvernance.
- Gestion des investissements. Ce domaine gère le portefeuille d'investissements de l'organisation en TI.
- Gestion de portefeuille. Ce domaine maximise la qualité des **analyses de rentabilisation des** investissements commerciaux axés sur la TI.

En se basant sur les "Quatre Ares" (tels que décrits par John Thorp dans son livre, *The Information Paradox-Realizing the Business Benefits of Information Technology*, rédigé conjointement avec Fujitsu, publié pour la première fois en 1998 et révisé en 2003, McGraw-Hill, Canada), les analyses de rentabilité doivent inclure les réponses aux quatre questions suivantes :

- L'organisation fait-elle ce qu'il faut ?
- L'organisation fait-elle les choses de la bonne façon ?

- L'organisation s'en acquitte-t-elle bien ?
- L'organisation en tire-t-elle des avantages ?

7. Le modèle eSAC

Le ***Cadre électronique de contrôle et d'audit des systèmes d'information (eSAC)*** est une publication de l'IIA. L'objectif de l'eSAC est de fournir un cadre de contrôle interne pour le commerce électronique. Dans le modèle eSAC, les processus internes de l'organisation acceptent les intrants et produisent des extrants.

- Entrées : Mission, valeurs, stratégies et objectifs
- Sorties : Résultats, réputation et apprentissage

Les objectifs généraux de contrôle du modèle eSAC sont influencés par ceux du cadre du COSO :

- Efficacité et efficience opérationnelles
- Communication de l'information financière et d'autres informations de gestion
- Conformité aux lois et règlements
- Sauvegarde des actifs

Les objectifs de l'eSAC en matière d'assurance des activités des TI se répartissent en cinq catégories :

- **Disponibilité.** L'organisation doit s'assurer que l'information, les processus et les services sont disponibles en tout temps.
- **Capacité.** L'organisation doit s'assurer que les transactions sont effectuées de façon fiable et en temps opportun.
- **Fonctionnalité.** L'organisation doit s'assurer que les systèmes sont conçus selon les spécifications de l'utilisateur pour répondre aux exigences opérationnelles.
- **Protection.** L'organisation doit s'assurer qu'une combinaison de contrôles physiques et logiques empêche l'accès non autorisé aux données du système ou leur utilisation.
- **Responsabilité.** L'organisation doit s'assurer que le traitement des transactions est exact, complet et non réfutable.

8. Guides pour l'évaluation des risques informatiques (GAIT)

La méthodologie GAIT fournit à la direction et aux auditeurs des orientations pour l'évaluation de la portée des contrôles généraux informatiques à l'aide d'une approche descendante et fondée sur les risques. La méthode GAIT est conforme à la norme de vérification 5 du Public Company Accounting Oversight Board et à d'autres cadres de contrôle, p. ex. le COSO. Les quatre principes de la méthodologie GAIT sont les suivants :

- L'identification des risques et des contrôles connexes dans les processus de contrôle général des TI devrait s'inscrire dans la continuité de l'approche descendante et fondée

sur les risques utilisée pour identifier les comptes importants, les risques pour ces comptes et les contrôles clés dans les processus opérationnels.

- Les risques liés au processus général de contrôle informatique qui doivent être identifiés sont ceux qui affectent les fonctionnalités informatiques critiques dans les applications financièrement significatives et les données associées.
- Les risques liés au processus de contrôle général des TI qui doivent être cernés existent, par exemple, dans le code du programme d'application, les réseaux et les systèmes d'exploitation.
- Les risques liés aux processus de contrôle général de la TI sont atténués par l'atteinte des objectifs de contrôle de la TI, et non par des contrôles individuels.

9. Contrôles formels et informels

L'expression « contrôles informels » est tirée d'une publication de Robert K. Mautz datant de 1980, intitulée *Internal Control in U.S. Corporations: The State of the Art (Le contrôle interne dans les entreprises américaines : l'état de la technique).*

Ce livre a clairement influencé les auditeurs internes. De manière générale, les contrôles formels sont par nature plus scientifiques et les contrôles informels plutôt orientés sur l'humain. Ces expressions peuvent être définies comme suit :

- **Contrôle formel.** Ces contrôles ont tendance à être quantitatifs et objectifs, ce qui signifie que les tests d'audit traditionnels peuvent être utilisés pour tester la conformité. Il s'agit, par exemple, d'inspecter des comptes rendus de réunion ou d'effectuer une analyse mensuelle budget - coût réel.
- **Contrôle informel.** Ces contrôles ont tendance à être qualitatifs et subjectifs et sont destinés à représenter la culture d'une organisation, tel que l'état d'esprit ou les perceptions. Par exemple, les contrôles informels peuvent inclure des politiques pour déterminer si les connaissances sont suffisantes pour corroborer des résultats ou étayer des conclusions.

L'illustration ci-dessous présente des exemples courants de ces deux types de contrôles.

Contrôles internes formels et informels

Exemples de contrôle formel	Exemples de contrôle informel
• Politique/procédure • Organigramme • Bureaucratie • Processus formels restrictifs • Processus décisionnel centralisé	• Compétences • Confiance • Valeurs partagées • Encadrement solide • Attentes élevées • Transparence • Normes d'éthique exigeantes

L'évaluation de l'efficacité et de l'efficience du contrôle est un concept de base traditionnel de l'activité d'audit interne. Toutefois, se concentrer uniquement sur les contrôles formels (par

exemple, politiques et procédures documentées) au niveau des processus aboutit à une évaluation incomplète. Pour évaluer le contrôle interne et fournir une assurance raisonnable à la direction générale et au conseil, l'activité d'audit interne doit inclure les contrôles informels intangibles et subjectifs.

Les modèles COSO et CoCo mettent l'accent sur les contrôles informels (voir Roth, "Taking a Hard Look at Soft Controls", *Internal Auditor*, février 1998). Par exemple, la communication des valeurs éthiques et la promotion de la confiance mutuelle sont des contrôles informels dans le modèle CoCo. Dans le modèle COSO, les contrôles informels font partie de l'environnement de contrôle. Il convient de distinguer les contrôles informels des contrôles rigoureux, tels que le respect de politiques et de procédures spécifiques imposées aux employés par des instances supérieures.

Les contrôles informels sont devenus de plus en plus nécessaires à mesure que les progrès technologiques ont donné plus de pouvoir aux employés. La technologie leur a donné accès à une grande quantité d'informations critiques et leur a permis de prendre des décisions autrefois prises par les échelons supérieurs de la structure organisationnelle. En plus de rendre obsolètes de nombreux contrôles durs, les progrès technologiques ont également permis l'automatisation des contrôles durs, par exemple, l'intégration de modules de vérification dans les programmes informatiques.

L'une des méthodes de vérification des contrôles informels est l'**autoévaluation des contrôles (CSA)**. Il s'agit de la participation de la direction et du personnel à l'évaluation des contrôles internes au sein de leur groupe de travail.

Les contrôles formels et informels peuvent être associés à des risques particuliers et mesurés. La vulnérabilité traitée peut être définie comme le produit de la probabilité d'occurrence et de l'importance de l'occurrence ($V = P \times S$).